SECURITY RESEARCH

Agentic Identity Pivots

Modeling Credential-Borne Lateral Movement in Breach Simulation

AEGIS Labs Research
Version 1.1 | July 2026

4.5×	≤ 2	0 Δ
Pivot-success spread from credential posture	Bounded credential pivots per path	Regression-locked on non-agentic estates

Table of Contents

1. Executive Summary

Enterprise estates are becoming *agentic*. Autonomous software agents now hold credentials, invoke tools, call one another, and increasingly reach external capability through Model Context Protocol (MCP) servers. This shifts the dominant lateral-movement surface. Where a human-operated intrusion pivots through stolen passwords and cached tokens, an agentic estate pivots through *shared secrets*: a static API key held by two agents makes each agent reachable from the other, and any tool either can invoke becomes reachable in turn.

Most breach-risk tooling does not model this. Credential abuse appears only as *technique vocabulary*, an ATT&CK label such as T1078 (Valid Accounts) or T1550.002 (Pass-the-Hash) attached to a kill-chain step. It never appears as a *relationship* where holding a specific credential grants the ability to act as a specific agent or reach a specific tool. A technique label tells you an actor *can* abuse valid accounts. It does not tell you *which* agents a compromised key actually unlocks, or how far the compromise spreads.

This paper describes how the Adversarix platform closes that gap. We add an *identity-pivot topology*, built from agent, credential, and tool entities joined by credential edges traversable in both directions, to the threat knowledge graph, and we make the Monte Carlo breach simulation *traverse* it. A shared-credential pivot becomes a real term in the breach-probability computation, with its own success probability drawn from the credential's posture and its own detection discount drawn from the technique it maps to. The result is a breach probability that accounts for agentic lateral movement rather than merely labeling it.

> **Key Finding**
>
> The success probability of a credential pivot is governed by credential posture, not by the technique label. A static key shared across agents yields a pivot-success probability of 0.90; a delegation-attenuated, short-lived token yields 0.20. That is a 4.5× spread that a technique-only model collapses to a single value. Because the pivot is structurally just another transition in the path, an estate with no agent or credential topology reproduces the pre-existing breach probability exactly.

2. The Agentic Lateral-Movement Surface

2.1 From accounts to shared secrets

Classical lateral movement is an account problem: an attacker who compromises one host harvests credentials, replays them, and moves to the next host. Detection and response programs are built around that model, with credential-access techniques, authentication telemetry, and privileged-account monitoring.

Agentic estates change the shape of the problem in three ways:

- **Agents are first-class principals.** An autonomous agent authenticates, holds secrets, and takes actions on its own schedule. Compromising the agent, or the secret it holds, is equivalent to compromising a principal, without a human in the loop to notice anomalous behavior.
- **Secrets are shared by construction.** Deployment convenience pushes teams toward shared API keys, service tokens reused across agents, and long-lived credentials baked into images. A single shared static key collapses the isolation between every agent that uses it.
- **Tools extend reach.** An agent that can invoke a tool, whether a database client, a cloud API, or an MCP server, extends the blast radius of its compromise to everything that tool can touch. MCP servers in particular act as capability hubs: reaching one can mean reaching many downstream systems.

The operational consequence is a *bidirectional* pivot primitive. If an attacker holds a credential, they can act as every agent that credential unlocks; and if they compromise an agent, they gain every credential that agent holds, which in turn unlocks further agents. Lateral movement in an agentic estate is a walk over this credential graph, and its reach is determined by how secrets are scoped, not by which ATT&CK technique the walk is labeled with.

2.2 Why a technique label is insufficient

Representing credential abuse as a technique label, T1078 or T1550.002, captures that an actor is *capable* of the abuse. It does not capture the estate-specific structure that determines how far the abuse propagates. Two organizations can both be "exposed to T1078" while having completely different real risk: one scopes every credential per agent and attenuates delegation; the other shares a single static key across its entire agent fleet. A technique-labeled model scores them identically. The difference is entirely in the topology, and the topology is exactly what a label omits.

3. Modeling Identity Pivots in the Threat Knowledge Graph

The Adversarix threat knowledge graph already represents the attack surface as a graph of assets, vulnerabilities, threat actors, techniques, campaigns, procedures, and detection analytics, joined by kill-chain and detection edges. The breach simulation walks technique-to-technique edges (`PRECEDES`) and computes breach probability as a product over the transitions on each path. The identity-pivot model extends this graph with a small, isolated set of entities and edges, and extends the traversal to walk them.

3.1 Entities and edges

Three new node types are introduced, kept isolated from the technique vocabulary so the pivot traversal can be reasoned about independently:

Node type	Role
Agent	An autonomous software principal. Runs on an inventory asset, holds credentials, and invokes tools.
Credential	A secret, such as an API key, service token, or delegated credential, that unlocks the ability to act as one or more agents.
Tool	A capability an agent can invoke. MCP servers are modeled as a tool with a server subtype.

These are joined by directional edges that encode the pivot semantics:

- `(Agent)-[RUNS_ON]->(Asset)` ties an agent to the inventory asset it lives on, connecting the identity topology to the existing asset and configuration-management model.
- `(Agent)-[HOLDS]->(Credential)` and `(Credential)-[UNLOCKS]->(Agent)` are the *bidirectional* credential edges. Traversal expands both ways: from a credential to every agent it unlocks, and from an agent to every credential it holds.
- `(Agent)-[INVOKES]->(Tool)` captures tool and MCP access.
- `(Agent|Credential|Tool)-[EXPOSES]->(Technique)` maps each pivot to the ATT&CK (or ATLAS) technique it realizes, so that detection applies to pivot steps exactly as it does to technique steps.

We deliberately reject modeling agents as a subtype of the asset entity with identity properties attached. Overloading the asset entity makes the credential-pivot traversal harder to isolate and harder to bound; dedicated node types keep the pivot logic self-contained.

3.2 The pivot maps to a technique so detection still applies

A credential pivot is not free lateral movement. Each pivot edge carries an `EXPOSES` link to the technique it realizes, whether Valid Accounts, Pass-the-Hash, or an AI-specific equivalent, and a pivot step is keyed in the simulation by that technique's identifier. The existing per-technique detection lookups therefore apply to pivot steps unchanged. Stealthy reuse of a static shared key, which typically has little or no detection coverage, produces a low detection discount and thus a high contribution to breach probability. That is the honest, intended signal: quiet credential reuse should raise risk, not disappear from it.

4. Pivot-Success Probability from Credential Posture

The load-bearing modeling decision is where a pivot's success probability comes from. In the technique walk, each `PRECEDES` edge carries a transition probability. The agentic analogue is that each credential edge carries a transition probability derived from the credential's *posture*: how it is scoped, whether it is shared, whether it rotates, and whether delegation is attenuated.

We pin a prior table of four posture classes:

Credential posture	Pivot success	Interpretation
Static key, shared across ≥2 agents	0.90	Trivial pivot. The shared secret collapses isolation between every agent that uses it.
Shared but rotated / not static	0.70	Rotation raises the bar, but shared use still enables pivoting within a rotation window.
Per-tool / per-agent scoped	0.40	Scoping confines the credential; a pivot requires additional compromise.
Delegation-attenuated / short-lived token	0.20	Short lifetime and attenuated delegation make a successful pivot the exception.

The loader stamps the resolved probability onto the credential edge, exactly as the technique walk stamps a transition probability onto each `PRECEDES` edge. These four numbers are the model's principal tunables. They are grounded in operational reasoning about credential hygiene and are flagged for empirical revision as agent-security posture connectors supply real distributions of credential scoping in the field. Publishing them as an explicit, revisable prior, rather than burying them in code, is deliberate: the posture-to-probability mapping is the part of the model a practitioner should scrutinize and re-tune for their own estate.

5. Traversal and the Breach Computation

5.1 A unified heterogeneous walk

The central design choice is to walk technique edges and identity-pivot edges in a *single* traversal, rather than running a separate credential-reachability pass whose result is reported as a side signal. A unified walk lets a path interleave the two edge types:

technique → … → compromise agent → [credential pivot] → other agent → technique → …

Each pivot edge becomes a transition in the breach computation with its own posture-derived success probability and its own detection step, keyed by the technique it exposes. Breach probability for a path remains the product of its per-step success terms, each discounted by detection; a pivot step simply contributes another factor. The overall breach probability across the paths discovered for a scenario is the probability that at least one path succeeds.

We reject the alternative, a parallel identity-reachability closure that feeds a "blast radius" signal while leaving the technique breach probability untouched. It is lower-risk to implement but keeps lateral movement out of the number that matters. The whole point is that agentic lateral movement should move breach probability, so the pivot must live inside the same computation as the technique walk.

5.2 Bounding path explosion

A dense agent-and-credential graph can explode the number of candidate paths. The traversal is bounded on several axes: a cap of two credential pivots per path, deduping of candidate paths by their node set, per-query result limits, and a transaction timeout. These mirror the depth discipline already applied to the technique walk and keep traversal cost predictable on large estates. Human and service accounts, and multi-hop delegation chains beyond the agent, credential, and tool triad, are deliberately out of the first-version scope; they are natural follow-on extensions once the triad is validated against field data.

6. The Regression Lock

Because the breach computation is the heart of the risk score, a non-negotiable invariant governs the whole feature: an estate with no identity topology must reproduce the pre-existing breach probability *exactly*.

The lock holds structurally rather than by special-casing. A pivot edge is just another entry in a path's transition sequence, carrying its own probability and its own technique key for the detection lookup. An organization with no agent or credential nodes yields technique-only paths, so the transition sequence is byte-identical to what it was before identity pivots existed. No additional random draw is issued, and the breach probability is bit-identical. This mirrors the same discipline the platform applies to its empirical detection posterior, where the no-data branch deliberately issues no extra draw. A dedicated regression test pins the invariant, and it ships before any behavioral change.

> **Why the lock matters**
>
> The identity-pivot model raises breach probability where shared-credential pivots create real spread. For organizations with agentic estates, that is the corrected, honest number, but it must be introduced without silently perturbing the scores of organizations that have no agentic exposure at all. The regression lock guarantees the change is *additive*: risk moves only where genuine identity topology is present.

7. Positioning and Related Work

The identity-pivot model is the grounding layer of a broader thread of AI-threat reasoning. Taxonomic coverage, meaning the enumeration of the AI/ML adversarial techniques an estate is exposed to, answers “which techniques apply.” The identity-pivot topology answers the operational question underneath it: “given this estate's agents, credentials, and tools, how far does a compromise actually spread, and how much does that move breach probability?” It converts an AI attack surface from a list of labels into a traversable structure the simulation can pivot through.

The model composes with an empirical detection posterior, that is, detection probabilities fit to real telemetry rather than assumed, so that pivot steps inherit realistic detection discounts. It also composes with the platform's polymorphic simulation strategies, so that credential pivots are evaluated across the same range of adversarial decision models (evasion-first, shortest-path, lateral-movement-varied, and others) as technique steps. The composite is a breach probability that reflects both *how* an adversary moves through an agentic estate and *how likely* that movement is to be seen.

8. Conclusion

As enterprise estates go agentic, shared-credential pivots become the dominant lateral-movement surface, and a threat model that represents credential abuse only as a technique label is blind to it. By adding an agent, credential, and tool topology to the threat knowledge graph, deriving pivot-success probability from credential posture, and walking the pivot inside the same Monte Carlo breach computation as the technique chain, the Adversarix platform makes agentic lateral movement a real, quantified term in breach probability. The posture-to-probability prior is published explicitly for scrutiny and re-tuning; the regression lock guarantees the model is purely additive for non-agentic estates. The result quantifies a class of risk, the quiet reuse of a shared static key spreading across an agent fleet, that technique-level models cannot express.

Citation. Galappatti, K. (2026). *Agentic Identity Pivots:*

Modeling Credential-Borne Lateral Movement in Breach Simulation

. AEGIS Labs, Adversarix, Inc. github.com/Adversarix/aegis-labs